

Cybersecurity Risk Register

&

Assessment

Healthcare Risk Assessment (Azure Environment)

Prepared by: Akachi Clement Egbeke

1. Organizational Context

ABC Healthcare Hamilton is a large, multi-site healthcare organization in Hamilton, Ontario. They provide acute care, mental health services, as well as outpatient treatment. This organization has an employee list of approximately 4,000+ staff, which includes clinicians, administrative personnel, as well as IT support teams.

The organization runs a hybrid IT environment made up of on-premise systems and cloud infrastructure primarily being hosted on Microsoft Azure. Their critical systems include Electronic Health Records (EHR), diagnostic imaging systems, patient portals, and also internal communication platforms.

As a healthcare organization, they process highly sensitive Personal Health Information (PHI) and Personally Identifiable Information (PII), and as such, making them subject to regulatory requirements under [PHIPA](#) and FI. The PHIPA component is required as the organization is based in Ontario.

This assessment aligns with security and risk management best practices outlined by [NIST](#) and [ISO](#).

2. Scope of Assessment

The scope includes cloud infrastructure, user access controls, data protection mechanisms, and compliance processes.

In-Scope systems:

- Cloud infrastructure
- Data protection mechanisms
- Access Management process: This covers the rules governing the process of provisioning and deprovisioning of user access.

In-Scope Frameworks:

- Personal Health Information Protection Act (PHIPA)
- Freedom of Information and Protection of Privacy Act (FIPPA)
- NIST
- ISO/IEC 27001:2022
- ISO/IEC 45001

Exclusions:

- Guest Wi-Fi networks
- Payroll Management
- Non-Medical IoT e.g. vending machines
- Physical infrastructure e.g. HVAC systems.

3. Risk Assessment Methodology

Organizational context was considered, and risks were assessed using qualitative ratings (Low, Medium, High) based on likelihood and impact. Controls were selected based on PHIPA (Privacy), FIPPA, NIST SP 800-30, ISO 27001 (Information Security) and ISO 45001 (Occupational Health and Safety). Inherent risk reflects the exposure level prior to any implemented controls altering the risk impact or likelihood, while residual risk reflects remaining exposure level after mitigation using controls.

4. Risk Register

Risk ID	Risk Description	Category	Likelihood	Impact	Inherent Risk	Controls (Mapped)	Residual Risk	Framework Mapping	Risk Owner
R1	Unauthorized access to PHI	Operational risk	Medium	High	High	Proper use & disclosure of information, Secure authentication.	Medium	PHIPA 13.1, FIPPA, ISO 27001 A. 6.6, ISO 27001 A. 8.5	Chief Privacy Officer (CPO)
R2	Phishing attack	Human risk	High	High	High	Information security Awareness, Education & Training	Medium	ISO 27001 A. 6.3	CISO
R3	Azure misconfiguration	Operational risk	Medium	Medium	Medium	Configuration Management	Low	ISO 27001 A. 8.9	Chief Technology Officer (CTO)
R4	Ransomware	Human risk	High	High	High	Information security awareness, Education & Training	Medium	ISO 27001 A. 6.3	CISO
R5	Regulatory non-compliance	Compliance risk	Medium	High	High	Practices & procedures review	Low	FIPPA, PHIPA 55.12	Chief Compliance Officer (CCO)
R6	Unsafe material storage	Operational risk	Medium	High	High	Eliminating Hazards	Low	ISO 45001 Clause 8.1.2, ISO 27001 A. 7.8	WHMIS Coordinator
R7	Improper Incident logging	Operational risk	High	Medium	Medium	Information security event reporting	Low	ISO 27001 A. 6.8	Clinical manager

5. Key Recommendations & Justifications

- Implement Zero Trust architecture to meet up with the proper use & disclosure of information suggested by PHIPA 13.1, FIPPA, ISO 27001 A. 6.6, and ISO 27001 A. 8.5
- Enhancing employee security awareness training in line with ISO 27001 A. 6.3 is a plus to ensuring compliance and improving security posture. Phishing campaigns should be run occasionally, and employees who fall victim should be subjected to retraining.
- To ensure compliance and adequate aligning with ISO 27001 A. 8.9 talking about configuration management, the implementation of automation (in the way of Terraform) would help give alerts if a setting is changed or compromised. Adequate and accurate inventory management is also another way to ensure all assets are documented and are rightly configured.
- The inclusion of the ISO 27001 A. 7.8 is to prevent the event of unsafely stored materials leading to fires and compromise of servers or systems in general. All boxes and/or fridges/freezers storing hazardous or radioactive content should have the signs associated with them as expressed by Workplace Hazardous Materials Information System (WHMIS).
- As always, conducting regular compliance audits and toughening endpoint detection and response ensures ongoing alignment.